

NOVICROM HUB

Security Pre-Production Audit

Evidence Report consolidato — patch SEC-PREPROD-01, SEC-PREPROD-02, SEC-PREPROD-03

Branch pre-prod-security — baseline f8005f8 — 2026-05-16

Classificazione: Interno — documento di evidenza remediation.

SEC-PREPROD-01 — Evidence Report

Progetto: NOVICROM HUB (Portale Novicrom / CRM-Brizio) Ambito: Patch security pre-produzione — header HTTP, guard CSRF, SQL logging, json_script Branch: pre-prod-security Baseline commit: f8005f8 — *Harden asset assignment and release guard* Data: 2026-05-16 Autore intervento: Application Security Engineer (sessione assistita) Classificazione documento: Interno — Evidence di remediation, propedeutico ad audit PDF Patch correlate: SEC-PREPROD-02 (object-level authorization), SEC-PREPROD-03 (stabilizzazione 5 test admin_portale)

Indice

- 1 Riepilogo modifiche
- 2 File modificati
- 3 Test eseguiti — esito
- 4 Test non eseguiti
- 5 Rischi residui
- 6 Prossima patch consigliata

1. Riepilogo modifiche

Patch security pre-produzione conservativa che chiude 4 finding di audit a basso rischio regressione. Nessun refactor, nessuna nuova dipendenza, nessun cambio UX o di logica business.

- A) Header security — In prod.py aggiunti `SECURE_CONTENT_TYPE_NOSNIFF = True` e `SECURE_REFERRER_POLICY = "same-origin"`.
- B) Guard CSRF — In prod.py aggiunto blocco `ImproperlyConfigured` (stesso pattern di `SECRET_KEY`) che impedisce l'avvio se `CSRF_TRUSTED_ORIGINS` è vuoto o contiene ancora `app.example.local / example.local`.
- C) SQL logging — In `validate_deployment.py` (`check_security()`) aggiunto check `SQL_LOG_ENABLED: FAIL` in ambiente prod, `WARN` fuori prod (non rompe dev/test).
- D) `json_script` — Sostituito `{{ var|safe }}` con `{{ var|json_script:"id" }}` in 3 template; il JS legge il JSON da `getElementById(...).textContent` con fallback `[] / {}`. Nomi delle variabili JS (`ASSETS`, `overrides`, `RISPOSTE_INIT`) invariati. Per `overrides_map` aggiunta una riga al context di `utente_edit` (l'oggetto Python già esisteva nella view).

2. File modificati

10 file modificati.

File	Modifica
django_app/config/settings/prod.py	header security + guard CSRF
django_app/core/management/commands/validate_deployment.py	check SQL_LOG_ENABLED
django_app/admin_portale/views.py	+ "overrides_map" nel context
django_app/admin_portale/templates/.../utente_edit.html	2× json_script
django_app/tickets/templates/tickets/pages/nuovo.html	json_script per ASSETS
django_app/tickets/templates/tickets/pages/gestione_detail.html	json_script per ASSETS
django_app/core/tests.py	+3 test ValidateDeploymentSecurityChecksTests

File	Modifica
django_app/tickets/tests.py	+1 test TicketNuovoAssetsJsonScriptTests
django_app/admin_portale/tests.py	+1 test smoke render utente_edit
CHANGELOG.md	voce ### Security sotto [Unreleased]

Nota operativa: 6 file target avevano l'attributo Windows read-only (R); rimosso temporaneamente, patchato, flag ripristinato. Verifica finale: tutti e 6 di nuovo A R.

3. Test eseguiti — esito

Comando	Esito
manage.py check --settings=config.settings.test	[OK] 0 issues
manage.py makemigrations --check --dry-run	[OK] No changes detected
core.tests + tickets.tests + admin_portale.tests (234 test)	[!] 229 OK, 5 FAIL preesistenti
5 nuovi test mirati (json_script + SQL_LOG check + smoke utente_edit)	[OK] tutti OK

Verifica regressioni: i 5 fail (AdminPortaleAuditLogTests, AdminPortaleUserAnagraficaSyncTests.test_toggle_active..., AdminPortaleAcldDiagnosticViewTests) sono stati confermati preesistenti: revertando l'unica modifica di logica di questa patch (overrides_map nel context) i fail persistono identici. Non sono causati dalla patch. Riguardano audit log bulk activate/deactivate, sync anagrafica e reason ACL OVERRIDE — aree non toccate.

Aggiornamento: i 5 FAIL preesistenti sono stati analizzati e chiusi con la patch dedicata SEC-PREPROD-03 — erano artefatti dell'ambiente di test (cache lru_cache non invalidata + test drift sui nomi badge), nessun bug applicativo.

4. Test non eseguiti

- Suite completa manage.py test (tutti i moduli) — eseguite solo le 3 suite richieste per tempi. Consigliato un run completo in CI prima del go-live.
- Test funzionale end-to-end del rendering JS in browser reale (la patch json_script è coperta da test di contenuto HTML, non da test di esecuzione JS).

5. Rischi residui

- 5 test preesistenti rotti in admin_portale — non introdotti da questa patch.
(Chiusi successivamente da SEC-PREPROD-03.)
- SEC-AUDIT-002 e SEC-AUDIT-004 non chiusi — IDOR download allegati e API write tickets restano aperti. *(Affrontati successivamente da SEC-PREPROD-02.)*
- json_script — se altri template/JS leggessero assets_list / overrides_map_json con il vecchio pattern non sono stati modificati: verificato che module_vis_json è inutilizzato e che overrides_map_json resta usato solo dal check template != '{}' (lasciato intatto).
- Guard CSRF — il guard in prod.py farà fallire l'avvio di un deploy che non ha valorizzato DJANGO_CSRF_TRUSTED_ORIGINS: comportamento voluto (fail-fast), ma va comunicato a chi gestisce il deploy.

6. Prossima patch consigliata

SEC-PREPROD-02 — Object-level authorization (i due Medium rimasti):

- SEC-AUDIT-004: aggiungere il check `_ticket_access_flags` nelle 4 API tickets (`_api_intervento_update / _delete`, `_api_componente_delete`, `api_crea_workorder`).
- SEC-AUDIT-002: decidere con il committente la granularità voluta sui download allegati (`diario_preposto`, `assets`) e, se per-oggetto, aggiungere il controllo di visibilità.

Inoltre, prima del go-live, separatamente: investigare i 5 test `admin_portale` preesistenti rotti — non sono security ma vanno chiariti. *(Indirizzato da SEC-PREPROD-03.)*

Per questa patch — scope limitato, 10 file, modifiche localizzate — non è stato necessario un team di agenti: gestita inline.

Fine documento — SEC-PREPROD-01 Evidence Report. Pronto per conversione in PDF di audit.

SEC-PREPROD-02 — Evidence Report

Progetto: NOVICROM HUB (Portale Novicrom / CRM-Brizio) Ambito: Patch security pre-produzione — object-level authorization (H1, M2, M3, M1) Branch: pre-prod-security Baseline commit: f8005f8 — *Harden asset assignment and release guard* Data: 2026-05-16 Autore intervento: Application Security Engineer (sessione assistita) Classificazione documento: Interno — Evidence di remediation, propedeutico ad audit PDF Patch correlate: SEC-PREPROD-01 (header / CSRF / SQL / json_script), SEC-PREPROD-03 (stabilizzazione 5 test admin_portale)

Indice

- 1 Rischi chiusi
- 2 File modificati
- 3 Policy implementate
- 4 Test aggiunti ed esiti
- 5 Failure preesistenti (non introdotte dalla patch)
- 6 acl_coverage_report
- 7 AUDIT EVIDENCE
- 8 Go / No-Go

Patch di hardening pre-produzione completata. Tutte le modifiche sono minime, senza refactor, senza nuove dipendenze, senza cambi DB / URL / UX.

1. Rischi chiusi

Finding	Descrizione	Esito
H1	rilevazione_incidenti.export_pdf — nessun controllo ruolo / IDOR su PII	[OK] Chiuso
M2	timbri.download_image — token Graph inviabile a host arbitrario	[OK] Chiuso
M3	rentri — CRUD registro rifiuti senza gate ruolo esplicito	[OK] Chiuso
M1	rilevazione_incidenti — viste lettura senza difesa in profondità	[!] Chiuso parzialmente (vedi note)

2. File modificati

File	Motivo security	Tipo
django_app/rilevazione_incidenti/views.py	H1: gate ruolo su export_pdf + fix 404 mascherato; M1: @login_required	Modifica
django_app/rilevazione_incidenti/tests.py	Test H1 + M1	Modifica
django_app/timbri/views.py	M2: allowlist host per token Graph	Modifica
django_app/timbri/tests.py	Test M2	Modifica
django_app/rentri/views.py	M3: gate ruolo scrittura	Modifica
django_app/rentri/tests.py	Test M3	Nuovo file
CHANGELOG.md	Voce [Unreleased] / Security	Modifica

3. Policy implementate

H1 — export_pdf

export_pdf genera il PDF solo se is_superuser OR _can_manage_rspp(request) OR _can_create(request) (gestori sicurezza / preposti / RSPP / admin). Altrimenti -> 403 reale con template forbidden. Rilevazione inesistente -> Http404 (eliminato il bug "template forbidden con status 404"). Nessun ruolo nuovo inventato — riusati gli helper esistenti del modulo.

M2 — _download_image

Nuovo helper _is_graph_trusted_host(url): accetta solo http(s) verso graph.microsoft.com, *.graph.microsoft.com, *.sharepoint.com. _download_image rifiuta (RuntimeError, nessuna requests.get) ogni URL fuori allowlist, senza hostname o con schema non valido. Timeout 30s già presente, mantenuto. Token mai loggato.

M3 — rentri CRUD

Nuovo helper _can_manage_rentri(request) (superuser o admin legacy) + _require_rentri_manager che ritorna JsonResponse 403. Applicato a tutte le scritture: carico / scarico_* / rettifica (_handle_form POST), modifica (POST), elimina, import_confirm, api_sync_pull. Lettura (elenco, export_pdf, import_preview) invariata. elimina resta @require_POST.

M1 — viste lettura rilevazione_incidenti

Aggiunto @login_required come difesa in profondità a lista, dettaglio, modifica, elimina, statistiche, heatmap, impostazioni, export_csv, export_pdf. Il blocco per-proprietario su dettaglio non è stato implementato: il modello RilevazioneIncidente non ha un concetto di proprietario/autore (il campo nominativo è testo libero, nessun created_by), quindi un gate per-owner richiederebbe refactor + cambio DB -> fuori scope (vedi Rischi residui).

4. Test aggiunti ed esiti

Comando	Esito
manage.py check --settings=config.settings.test	[OK] System check identified no issues
manage.py makemigrations --check --dry-run	[OK] No changes detected
test rilevazione_incidenti.tests timbri...HostAllowlistTests rentri.tests	[OK] 24 test OK
test core.tests tickets.tests admin_portale.tests (baseline)	[OK] 235 test OK
test ... 6 moduli (suite estesa)	277 test — 3 fail + 1 error (tutti preesistenti timbri)
acl_coverage_report --max-missing 0	[FAIL] Fallita per gap preesistente (vedi §6)
git diff --check (file patch)	[OK] Nessun problema whitespace

Test nuovi:

- ExportPdfAuthorizationTests (5): basic -> 403, RSPP -> 200, superuser -> 200, sp_id mancante -> 404, regressione 403/404 coerenti.
- ReadViewsAuthGuardTests + ReadViewsAuthenticatedAccessTests (M1).
- TimbriDownloadImageHostAllowlistTests (5): graph -> Authorization, sharepoint ->

Authorization, host untrusted -> no download, sharepoint.com solo in query -> rifiutato, schema/host mancante -> rifiutato.

- RentriWriteAuthorizationTests (8): create / modify / delete / import / sync gated, delete solo POST.

5. Failure preesistenti (non introdotte dalla patch)

Confermate identiche eseguendo `timbri.tests` sul codice pre-patch via `git stash -> FAILED` (failures=3, errors=1):

- `TimbriViewTests.test_caporeparto_can_view_but_cannot_create` — 302 (redirect onboarding utente non-superuser senza `UserOnboarding`).
- `TimbriAnagraficaIntegrationTests.test_anagrafica_list_shows_timbri_link` — 302.
- `TimbriDownloadAuditTests.test_serve_timbri_image_denied_...` — 302.
- `TimbriViewTests.test_reset_table_deduplicates_uppercase_legacy_rows` — ERROR.

Nota: una esecuzione della suite estesa ha mostrato 8 failure (vs 3) per flakiness preesistente di isolamento test tra app (tabella raw anagrafica_dipendenti / sqlite in `.tmp_tests`); `core` + `tickets` + `admin_portale` da soli sono 235 OK stabili.

6. acl_coverage_report

Fallita con 76 route applicative senza binding canonico. Preesistente: il baseline documentato in `CLAUDE.md` è `--max-missing 222`; la patch non aggiunge né rimuove URL. Come da istruzioni, ACL non è stata modificata -> patch separata di copertura ACL.

7. AUDIT EVIDENCE

7.1 Finding chiusi

Finding	Severità	Stato	Patch	Test
H1 — export_pdf IDOR/PII	High	Chiuso	Gate superuser / <code>_can_manage_rspp</code> / <code>_can_create</code> + <code>Http404</code> su risorsa mancante	<code>ExportPdfAuthorizationTests</code> (5)
M2 — <code>_download_image</code> SSRF / leak token	Medium	Chiuso	<code>Helper_is_graph_trusted_host</code> + allowlist host	<code>TimbriDownloadImageHostAllowlistTests</code> (5)
M3 — <code>rentri write</code> senza gate ruolo	Medium	Chiuso	<code>_can_manage_rentri</code> + <code>_require_rentri_manager</code> su 5 endpoint scrittura	<code>RentriWriteAuthorizationTests</code> (8)
M1 — viste lettura senza difesa in profondità	Medium	Chiuso parziale	<code>@login_required</code> su 9 viste	<code>ReadViewsAuthGuardTests</code> , <code>ReadViewsAuthenticatedAccessTests</code>

7.2 File modificati

File	Motivo security	Tipo modifica
<code>django_app/rilevazione_incidenti/views.py</code>	H1: gate ruolo + 404 reale; M1: <code>@login_required</code>	Modifica codice
<code>django_app/rilevazione_incidenti/tests.py</code>	Copertura test H1 + M1	Modifica test
<code>django_app/timbri/views.py</code>	M2: allowlist host token Graph	Modifica codice
<code>django_app/timbri/tests.py</code>	Copertura test M2	Modifica test

File	Motivo security	Tipo modifica
django_app/rentri/views.py	M3: gate ruolo scrittura	Modifica codice
django_app/rentri/tests.py	Copertura test M3	Nuovo file test
CHANGELOG.md	Tracciabilità security	Modifica doc

7.3 Comandi eseguiti

- `python manage.py check --settings=config.settings.test -> OK — System check identified no issues (0 silenced).`
- `python manage.py makemigrations --check --dry-run --settings=config.settings.test -> OK — No changes detected (nessuna migrazione, coerente con il vincolo "no DB change").`
- `Test mirati rilevazione_incidenti.tests + timbri.tests.TimbriDownloadImageHostAllowlistTests + rentri.tests -> OK — Ran 24 tests ... OK.`
- `Test estesi `core.tests tickets.tests admin_portale.tests rilevazione_incidenti.tests timbri.tests rentri.tests -> Ran 277 tests – FAILED (failures=3, errors=1): i 4 falli sono preesistenti in timbri.tests (confermato via git stash sul codice pre-patch: stesso FAILED (failures=3, errors=1))`.`
- `Baseline core.tests tickets.tests admin_portale.tests -> OK — Ran 235 tests ... OK.`
- ``python manage.py acl_coverage_report --include-admin --format json --fail-on-missing --max-missing 0 --settings=config.settings.test -> **FALLITA**:` ACL coverage check failed: 76 route applicative senza binding canonico – gap preesistente (baseline progetto --max-missing 222`), nessuna route aggiunta/rimossa dalla patch.
- `git diff --check (file patch) -> OK, nessun problema whitespace.`
(CLAUDE.md:103 new blank line at EOF è preesistente, file non parte di SEC-PREPROD-02.)
- `git status --short -> M CHANGELOG.md, M django_app/rentri/views.py, M django_app/rilevazione_incidenti/tests.py, M django_app/rilevazione_incidenti/views.py, M django_app/timbri/tests.py, M django_app/timbri/views.py, ?? django_app/rentri/tests.py.`

7.4 Evidenza remediation

H1 — rilevazione_incidenti.export_pdf

- Prima: nessun controllo; qualunque utente con accesso ACL al modulo scaricava il PDF (PII, descrizioni infortunio, 5WHY, note RSPP) di qualsiasi rilevazione via `sp_id`. Risorsa mancante -> template forbidden con status 404 incoerente.
- Dopo: generazione consentita solo a superuser / preposti / RSPP; non autorizzato -> 403 reale; rilevazione inesistente -> 404 reale (Http404).
- Test: `ExportPdfAuthorizationTests.test_basic_module_user_is_forbidden (403), test_rspp_user_is_allowed / test_superuser_is_allowed (200), test_missing_incident_returns_404..., test_denied_is_real_403_and_missing_is_real_404.`
- Rischio residuo: con whitelist `acl_preposti` vuota, `_can_create` resta aperto a tutti gli autenticati (comportamento documentato L3, fuori scope) — l'export PDF resta comunque non più debole del dettaglio.

M2 — timbri._download_image

- Prima: `requests.get(url, headers={Authorization: Bearer <graph_token>})` su URL

preso dai campi della lista SharePoint; un URL verso host non Microsoft riceveva il bearer token Graph.

- Dopo: token e download solo verso host in allowlist Graph / SharePoint; URL non attendibili / malformati -> RuntimeError senza alcuna richiesta HTTP.
- Test: `TimbriDownloadImageHostAllowlistTests` — Authorization presente per `graph.microsoft.com / *.sharepoint.com`; `attacker.local` e `attacker.local/?ref=sharepoint.com` non scaricati; schema/host invalidi rifiutati.
- Rischio residuo: nessuno per il vettore identificato; resta la fiducia implicita nei contenuti delle liste SharePoint configurate (sorgente amministrativa).

M3 — `rentri` CRUD

- Prima: creazione / modifica / eliminazione / import del registro rifiuti (dato a valenza legale) protetti solo da login + ACL di path, senza gate ruolo nel modulo.
- Dopo: scritture consentite solo a superuser / admin legacy; altri -> `JsonResponse 403` senza alcuna modifica. elimina resta solo POST.
- Test: `RentriWriteAuthorizationTests` — basic user bloccato su `create / modify / delete / import / sync` (403, dato invariato), admin consentito, GET su `elimina` -> 405.
- Rischio residuo: la lettura (elenco, `export_pdf`) resta secondo ACL di modulo — coerente con la richiesta.

M1 — `viste lettura` `rilevazione_incidenti`

- Prima: nessun `@login_required`, dipendenza esclusiva dal middleware ACL.
- Dopo: `@login_required` su tutte le viste principali (difesa in profondità).
- Test: `ReadViewsAuthGuardTests` (anonimo -> redirect login), `ReadViewsAuthenticatedAccessTests` (accesso autenticato funzionante).
- Rischio residuo: nessun gate per-proprietario su dettaglio (vedi Rischi residui).

7.5 Rischi residui

Rischio	Owner consigliato	Priorità	Scadenza	Accettabilità in produzione
ACL coverage: 76 route senza <code>RoutePermissionBinding</code> canonico (a <code>cl_coverage_report --max-missing 0</code> fallisce)	Team ACL / Platform	Media	Prossima patch ACL pre-GA	Accettabile: baseline progetto è <code>--max-missing 222</code> , nessuna route nuova introdotta; il middleware ACL + fallback legacy resta attivo
M1 per-owner su dettaglio / lista: ogni utente con accesso al modulo vede tutte le rilevazioni (no concetto di proprietario nel modello)	Owner modulo Sicurezza	Bassa	Da decidere con business	*Needs manual decision*: implementare lo scoping richiederebbe refactor + nuovo campo <code>created_by</code> (cambio DB). Accettabile ora: H1 chiude l'esposizione PDF; la lista incidenti è plausibilmente a trasparenza di reparto

Rischio	Owner consigliato	Priorità	Scadenza	Accettabilità in produzione
L1-L4 + bug campaign _remove_document	Team Security	Bassa	Patch successive (già pianificate)	Accettabile: esplicitamente esclusi dallo scope di questa patch
Flakiness isolamento test suite estesa (tabella raw anagrafica_dipendenti, sqlite in .tmp_tests)	Team QA	Bassa	Backlog QA	Accettabile: non di sicurezza; non blocca il deploy. *(Causa analizzata e mitigata in SEC-PREPROD-03.)*
4 test preesistenti falliti in timbri.tests (redirect onboarding / dedup legacy)	Owner modulo Timbri	Bassa	Backlog	Accettabile: preesistenti, non legati a SEC-PREPROD-02 (confermato su codice pre-patch)

8. Go / No-Go

GO per i finding in scope: H1, M2, M3 chiusi e testati; M1 chiuso come difesa in profondità. Nessuna regressione introdotta (check OK, nessuna migrazione, baseline core / tickets / admin_portale 235 OK, falli residui tutti preesistenti e confermati).

Resta condizionato — non bloccante per questa patch — il follow-up sulla copertura ACL (76 route) e la decisione manuale sullo scoping per-proprietario di rilevazione_incidenti, da indirizzare in patch dedicate prima della GA.

Fine documento — SEC-PREPROD-02 Evidence Report. Pronto per conversione in PDF di audit.

SEC-PREPROD-03 — Evidence Report

Progetto: NOVICROM HUB (Portale Novicrom / CRM-Brizio) Ambito: Stabilizzazione test pre-produzione — chiusura 5 FAIL admin_portale Branch: pre-prod-security Baseline commit: f8005f8 — *Harden asset assignment and release guard* Data: 2026-05-16 Autore intervento: Application Security Engineer (sessione assistita) Classificazione documento: Interno — Evidence di remediation, propedeutico ad audit PDF Relazione con altre patch: follow-up di SEC-PREPROD-01

Indice

- 1 Contesto
- 2 Root cause dei 5 failure
- 3 Distinzione test drift vs bug reale
- 4 File modificati
- 5 Test eseguiti
- 6 Stato finale
- 7 AUDIT EVIDENCE
- 8 Rischi residui

1. Contesto

A valle dell'audit security pre-produzione (0 Critical, 0 High, 4 Medium, Go condizionato) è stata applicata la patch SEC-PREPROD-01 che ha chiuso 4 finding a basso rischio regressione:

- header di sicurezza HTTP (SECURE_CONTENT_TYPE_NOSNIFF, SECURE_REFERRER_POLICY);
- guard CSRF_TRUSTED_ORIGINS contro i valori placeholder;
- check SQL_LOG_ENABLED in validate_deployment;
- sostituzione json.dumps + |safe con json_script nei template.

I test mirati nuovi passavano, ma la suite admin_portale presentava 5 FAIL preesistenti (non introdotti dalla patch). Questo documento raccoglie l'analisi e la remediation di quei fallimenti.

Vincoli dell'intervento: non toccare la patch security precedente, nessun refactor, nessun cambio UX, nessuna modifica di logica business salvo bug reale dimostrato, mantenere intatta la copertura security/audit/ACL.

I 5 FAIL segnalati si raggruppano, in pratica, in 4 test rotti distribuiti su 3 classi:

Classe	Test
AdminPortaleAuditLogTests	test_utenti_bulk_activate_is_audited
AdminPortaleAuditLogTests	test_utenti_bulk_deactivate_is_audited
AdminPortaleUserAnagraficaSyncTests	test_toggle_active_moves_user_into_central_anagrafica
AdminPortaleAclDiagnosticViewTests	test_acl_diagnostica_returns_structured_reason_and_context

2. Root cause dei 5 failure

Causa A — Cache lru_cache stale tra test (3 fail)

Test coinvolti: test_utenti_bulk_activate_is_audited, test_utenti_bulk_deactivate_is_audited, test_toggle_active_moves_user_into_central_anagrafica.

legacy_table_columns() in django_app/core/legacy_utils.py:475 è decorata @lru_cache(maxsize=32) — cache per-processo, persistente tra i test.

Sequenza del bug:

- 1 Un test eseguito prima invoca legacy_table_columns("anagrafica_dipendenti") quando la tabella *unmanaged* ha uno schema diverso (o non esiste ancora) -> la cache memorizza un elenco colonne stale.
 - 1 Il TestCase Django esegue il rollback della transazione, ma la lru_cache Python non viene invalidata.
 - 1 Il test successivo ricrea la tabella e chiama upsert_anagrafica_dipendente -> ensure_anagrafica_schema() restituisce le colonne cached (incoerenti con la tabella reale) -> INSERT con una colonna inesistente -> OperationalError: no such column: ruolo.
 - 1 L'eccezione viene catturata silenziosamente da _audit_safe / except Exception nella view -> l'audit non viene scritto e il flag attivo resta invariato (rollback dell'intero transaction.atomic()).
- Diagnosi confermata sperimentalmente: spy su _sync_legacy_user_to_anagrafica -> SYNC RAISED: OperationalError no such column: ruolo. Applicando legacy_table_columns.cache_clear() nel setUp, i 3 test passano.

Causa B — Test drift sui nomi badge (1 fail)

Test coinvolto: test_acl_diagnostica_returns_structured_reason_and_context (django_app/admin_portale/tests.py, righe ~2657-2658).

Il test falliva su assertIn("OVERRIDE", diag["badges"]):

```
AssertionError: 'OVERRIDE' not found in  
['LEGACY_FALLBACK', 'REGISTRY', 'REDIRECT', 'LEGACY_MATCH', 'LEGACY_OVERRIDE']
```

La view acl_diagnostica genera i badge tramite _acl_diag_badges() (django_app/admin_portale/views.py:4460), che usa nomi granulari LEGACY_OVERRIDE / LEGACY_FALLBACK. Il test si aspettava i nomi semplici OVERRIDE / LEGACY, che appartengono a un altro generatore di badge (views.py:4826, usato dalla pagina *mappa permessi* — schema legittimamente diverso, coperto e verde nel test test_map_page_shows_badges_for_registry_legacy_override_and_redirect).

Il test era rimasto indietro rispetto al refactor dei badge della diagnostica ACL: test drift puro, nessun malfunzionamento del codice.

3. Distinzione test drift vs bug reale

Failure	Categoria	Esito
test_utenti_bulk_activate_is_audited	Setup test incompleto (cache non invalidata)	Corretto solo il test
test_utenti_bulk_deactivate_is_audited	Setup test incompleto	Corretto solo il test
test_toggle_active_moves_user_into_central_anagrafica	Setup test incompleto	Corretto solo il test
test_acl_diagnostica_returns_structured_reason_and_context	Test drift (aspettativa vecchia)	Corretto solo il test

Nessun bug reale di codice applicativo. A runtime, in produzione, lo schema delle tabelle legacy è stabile: la lru_cache è coerente e il problema non si manifesta. Il fallimento era esclusivamente un artefatto dell'ambiente di test (tabelle *unmanaged* + cache per-processo non invalidata tra test).

Di conseguenza non è stato modificato codice applicativo e — per la regola "aggiorna CHANGELOG solo se modifichi codice applicativo" — il CHANGELOG.md non è stato toccato.

4. File modificati

File	Motivo security	Tipo modifica
django_app/admin_portale/tests.py	Ripristina l'affidabilità della copertura audit/ACL: i test mascheravano un OperationalError senza segnalarlo. Nessun codice applicativo toccato.	Solo test: import legacy_table_columns; cache_clear() nell'helper _ensure_anagrafica_table(); allineamento dei nomi badge attesi nel test diagnostica ACL

Dettaglio modifiche (solo test):

- 1 Import — aggiunto from core.legacy_utils import legacy_table_columns.
- 2 Invalidazione cache — in _ensure_anagrafica_table() aggiunta la chiamata

legacy_table_columns.cache_clear() dopo aver garantito lo schema corrente della tabella, con commento esplicativo. Scelta della soluzione minima: il cache_clear() è inserito nell'helper condiviso (un solo punto) invece che nei singoli setUp, così ogni test che ricrea la tabella anagrafica invalida automaticamente la cache.

- 1 Nomi badge — nel test test_acl_diagnostica_returns_structured_reason_and_context, sostituite le asserzioni assertIn("OVERRIDE", ...) / assertIn("LEGACY", ...) con i nomi realmente prodotti per lo scenario final_decision_source == "legacy_fallback" con override utente: assertIn("LEGACY_OVERRIDE", ...) / assertIn("LEGACY_FALLBACK", ...).

Copertura security/audit/ACL invariata — nessuna asserzione rimossa, solo aggiornati i nomi badge attesi a quelli reali.

5. Test eseguiti

Comando	Esito	Sintesi output
python manage.py check --settings=config.settings.test	[OK] OK	"System check identified no issues (0 silenced)."
python manage.py makemigrations --check --dry-run --settings=config.settings.test	[OK] OK	"No changes detected"
python manage.py test admin_portale.tests --settings=config.settings.test	[OK] OK	"Ran 102 tests ... OK"
python manage.py test core.tests tickets.tests admin_portale.tests --settings=config.settings.test	[OK] OK	"Ran 235 tests ... OK"
git diff --check	[!] Preesistente	Unico segnale CLAUDE.md:103: new blank line at EOF — non di questa patch (CLAUDE.md non toccato). git diff --check django_app/admin_portale/tests.py pulito
git status --short django_app/admin_portale/tests.py	[i]	M django_app/admin_portale/tests.py — unico file di questa patch
acl_coverage_report	— Non eseguito	La patch non modifica RoutePermissionBinding, route, ACL v2 né navigazione: solo file di test. Comando non pertinente

6. Stato finale

Tutti i 5 FAIL chiusi. Suite core + tickets + admin_portale completamente verde (235/235 test OK). La patch security precedente (SEC-PREPROD-01 — header / CSRF / SQL log / json_script) non è stata toccata. Nessun refactor, nessun cambio UX, nessuna modifica di logica business.

7. AUDIT EVIDENCE

7.1 Finding chiusi

Finding	Severità	Stato	Patch	Test
test_utenti_bulk_activate_is_audited FAIL	Bassa (test-only)	Chiuso	cache_clear() in ensure_anagrafica_table()	admin_portale.tests.AdminPortaleAuditLogTests.test_utenti_bulk_activate_is_audited [OK]
test_utenti_bulk_deactivate_is_audited FAIL	Bassa (test-only)	Chiuso	cache_clear() in ensure_anagrafica_table()	admin_portale.tests.AdminPortaleAuditLogTests.test_utenti_bulk_deactivate_is_audited [OK]
test_toggle_active_moves_user_into_central_anagrafica FAIL	Bassa (test-only)	Chiuso	cache_clear() in ensure_anagrafica_table()	admin_portale.tests.AdminPortaleUserAnagraficaSyncTests.test_toggle_active_moves_user_into_central_anagrafica [OK]
test_acl_diagnostics_returns_structured_reason_and_context FAIL	Bassa (test drift)	Chiuso	Aggiornati i nomi badge attesi	admin_portale.tests.AdminPortaleACLDiagnosticViewTests.test_acl_diagnostics_returns_structured_reason_and_context [OK]

Il prompt cita "5 FAIL"; le classi raggruppano in pratica 4 test rotti. Tutti e 4 chiusi.

7.2 File modificati

File	Motivo security	Tipo modifica
django_app/admin_portale/tests.py	Ripristina l'affidabilità della copertura audit/ACL (i test mascheravano un OperationalError) — nessun codice applicativo toccato	Solo test: import + invalidazione cache in helper condiviso + allineamento nomi badge

7.3 Comandi eseguiti

- python manage.py check --settings=config.settings.test -> OK — "System check identified no issues (0 silenced)".
- python manage.py makemigrations --check --dry-run --settings=config.settings.test -> OK — "No changes detected".
- python manage.py test admin_portale.tests --settings=config.settings.test -> OK — "Ran 102 tests ... OK".

- `python manage.py test core.tests tickets.tests admin_portale.tests --settings=config.settings.test`
-> OK — "Ran 235 tests ... OK".
- `git diff --check` -> un solo segnale CLAUDE.md:103: new blank line at EOF —
preesistente, non di questa patch (CLAUDE.md non toccato); `git diff --check`
django_app/admin_portale/tests.py pulito.
- `git status --short django_app/admin_portale/tests.py` ->
M django_app/admin_portale/tests.py — unico file di questa patch.
- `acl_coverage_report` -> non eseguito: la patch non modifica `RoutePermissionBinding`,
route, ACL v2 né navigazione — solo file di test. Comando non pertinente.

7.4 Evidenza remediation

Finding A — 3 test audit/sync (cache stale)

- Comportamento vulnerabile prima: eseguiti in suite, `legacy_table_columns` restituiva
colonne stale -> INSERT in `anagrafica_dipendenti` con colonna ruolo inesistente -> `OperationalError` ->
`transaction.atomic()` in rollback -> audit non scritto / attivo invariato. Test rossi in modo non deterministico
(dipendente dall'ordine di esecuzione).
- Comportamento dopo la patch: `_ensure_anagrafica_table()` invalida la cache via
`legacy_table_columns.cache_clear()` dopo aver garantito lo schema corrente -> ogni test riparte da una cache
coerente.
- Test che dimostra la correzione: i 3 test passano sia isolati sia in suite completa
(235/235 OK); verificato in anticipo tramite patch sperimentale del `setUp` (`FAILURES with cache_clear: 0`).
- Rischio residuo: il pattern `lru_cache` per-processo resta; altre suite con tabelle
`legacy *unmanaged*` potrebbero ripresentare il drift (priorità bassa).

Finding B — test diagnostica ACL (test drift)

- Comportamento vulnerabile prima: il test asseriva i badge `OVERRIDE` / `LEGACY`, nomi
non più prodotti da `_acl_diag_badges()` per la view `acl_diagnostica` (refactor a badge granulari `LEGACY_*`).
- Comportamento dopo la patch: il test asserisce `LEGACY_OVERRIDE` / `LEGACY_FALLBACK`,
i nomi effettivamente generati per lo scenario `final_decision_source == "legacy_fallback"` con override
utente.
- Test che dimostra la correzione:
`test_acl_diagnostica_returns_structured_reason_and_context` [OK]; la copertura badge dell'altra view resta
verde (`test_map_page_shows_badges_for_registry_legacy_override_and_redirect`).
- Rischio residuo: nessuno — la logica `_acl_diag_badges()` è internamente coerente e
non è stata modificata.

8. Rischi residui

Rischio	Owner consigliato	Priorità	Scadenza consigliata	Accettabile in produzione?
lru_cache legacy_table_columns non isolata tra test	Team backend / QA	Bassa	Prossimo ciclo di hardening test	Sì — non impatta il runtime di produzione (schema legacy stabile); è solo flakiness di test
_audit_safe / except Exception silenziano errori DB reali	Team backend	Bassa	Da valutare in revisione audit trail	Sì — comportamento fire-and-forget intenzionale; consigliato passare a log warning per visibilità
SEC-AUDIT-002 (IDOR download allegati) e SEC-AUDIT-004 (API write tickets)	Security engineer	Media	Patch successiva, prima del go-live	Solo se accettato formalmente dal committente — fuori scope di questo intervento

Fine documento — SEC-PREPROD-03 Evidence Report. Pronto per conversione in PDF di audit.